系统审计报告

产品版本：

报告日期：

范围：功能完成度　合规与正确性　安全　体验　缺口与路线图

总体评分（主观）：业务核心约　　生产合规约

关键缺口：正式环境数字签名未接入　金额仍为　　存储

一、执行摘要

本系统是面向单店修车行的本地　桌面
　　，覆盖工单、报价　发票　收据、库存、柜台钱箱、供应商进货以及马来西亚
电子发票。权限模型、金额四舍五入、关柜公式、
自动升级与买家扫码填资料等设计较为扎实。　　已补齐：提交后自动轮询
　、工单持久化　　（刷新可续查）、发票　收据上的「顾客请求
　　」与「　　验证」两种二维码。

当前最影响「正式开票」的缺口是未实现数字证书　　签名；其次是金额用浮点存储、打印仍依赖浏览器、以及缺少核心公式的自动化测试。沙盒联调可用；正式环境需在签名策略明确后再推广。

二、已达成且质量较好（　　）

核心业务

模块	状态	说明
工单流程		草稿　报价　确认　完工　发票　收款
客户　车辆		车牌关联、资料复用
库存		入库、扣减、成本价仅老板可见
报价　发票　收据		打印布局、签名、付款与支付
		关联原发票、退款、可走
供应商发票　付款凭证		预填、入库、分期、钱箱扣款
柜台开　关柜		备用金、面额点钞、长短款、存银行
报表　仪表盘		老板可见利润；员工端隐藏敏感数据
多语言		中　英　马
桌面端		固定端口、更新检查、备份能力

安全与账号

项	状态	说明
（ 密码指纹）		改密使旧会话失效
登录防暴力破解		按用户名阶梯锁定
防护		
安全响应头		等相关头
老板　员工权限		服务端　　校验
公开买家填表		不可猜　　、限流、锁定规则

税务、金额与

项	状态	说明
计算		税率、范围
四舍五入到分		预览　保存　打印　　一致
提交前总额对账		与发票总额不一致则拒绝
、沙盒切换		配置
单张　　月结合并		提交与状态查询
查		
自动轮询		：约　　起、每　　、最多　　次
持久化		：刷新可续查
验证二维码		有　　后显示
顾客请求		：未提交前显示
旧库　　自动升级		只增不改列　表

三、明确缺失或未完成

缺口	严重度	影响
正式环境数字签名（ 证书）	缺失	正式提交常因 被拒；当前仅
金额 存储	缺失	长期对账可能出现 偏差；宜改「分」整数
后台无人值守轮询	缺失	离开页面即停轮询（刷新可续依赖 ）
角色未落地	缺失	有角色，业务权限几乎未用
核心逻辑自动化测试	缺失	税、关柜、 易在改动时静默出错
热敏小票 专业 导出	缺失	依赖浏览器
可选「禁止无货完工」	缺失	库存不足仍可完工，仅扣到

四、可改进项（已有基础）

领域	现状	建议
两种 文案	已区分请求 验证	加强中英马；预览区提示「先请求、后验证」
请求 地址	局域网 可选环境变量	设置页预览顾客将打开的完整
错误信息	常为原始	映射成人话：缺 、签名、重复提交等
占位	无 不显示占位	与发票一致显示「等待 」
多设备钱箱	开柜全局一份	绑定设备名或第二台只读提示
车牌输入	普通文本	自动大写、去空格
备份恢复	有备份能力	一键恢复 强确认 自检
正式签名说明	提交失败时有部分提示	设置页固定标明「未内置证书签名」

五、 对照

能力	此前	
验证	有	有
提交后自动查状态	仅手动	自动轮询（可手动）
刷新后继续查	工单无 ，易丢	已持久化并可续查
顾客填资料	后端有、打印未接	发票 收据已显示
数字签名	无	仍无
金额	有	仍有
版本号		
评估文档	无	

六、风险评级摘要

风险	等级	说明
正式环境无法稳定开	高	缺数字签名，合规与过账受阻
长期金额对账偏差	中	累积误差；业务层 可缓解

风险	等级	说明
现场扫错　连错	中	请求　　依赖局域网；需　　可见性
库存与实货不一致	中	可卖空策略；缺欠料报表时难发现
会话与权限绕过	低	、　　、服务端角色校验较完整
公开　　被猜中	低	随机　　限流　提交锁定

七、建议优先级与下一版范围

建议优先级

优先级	项	类型
	数字签名对接，或产品明确「仅沙盒　非正式」	缺失　定位
	错误人话化	改进
	热敏收据　　导出	缺失
	缺货警告　欠料列表	改进
	请求　　的完整　　预览	改进
	金额改「分」整数存储	缺失
	后台轮询　　单据	改进
	多设备钱箱策略	改进
	落地或删除	清理
	关柜公式单元测试	缺失

建议的　　小版本切片（可执行）

设置页固定说明：正式环境需数字证书，当前版本未内置签名。

　　提交　查状态　查　　错误映射为人话（中英）。

完工时库存不足醒目警告。

发票预览区显示顾客请求　　对应的完整　　。

更新版本说明与自测清单（请求　　提交　轮询　验证　　刷新续查）。

热敏打印、金额整数、后台轮询、签名接入可单独立项为后续大版本。

八、审计结论

作为单店修车　　，主流程、权限、钱箱、库存与　　计算已达到可日常使用水平；联调链路（提交、状态、两种二维码、自动轮询与　　）在已闭环。在接入正式数字签名之前，不应将「生产环境稳定开具合法　　」列为已交付能力。建议将签名策略与错误可读性作为下一发布的硬门槛，其余按现场痛点（打印、欠料、多设备）迭代。

文档索引：仓库内　　本
生成说明：基于代码库静态审查与　　已实现变更；未包含渗透测试或　　正式环境实测。